

FARI

Example Investigation Report OSDLP Telecommand Library Fuzzing

Release source: 01-library-fuzzing-report.md

FARI v1.3.0 | 2026-08-23

DOES NOT MEET

Qualitative executive conclusion from the example report

This is the versioned release edition of the FARI documentation bundle. Canonical working sources for this release are stored under the same version folder.

Document Control

- **Assessment ID:** ASM-FARI-2026-001
- **Report version:** 0.2
- **Report maturity:** Provisional
- **Report date:** 2026-06-07
- **Source material:** cases/01_Lib.md (../cases/01_Lib.md)
- **Evidence producer:** Auditor; identity not supplied
- **Report author:** FARI Report Author
- **Mission owner / risk authority:** Not supplied
- **Framework profile:** No external framework profile was required for this report.

1. FARI Result Card

Field	Result
Conclusion	Does Not Meet
Confidence	High for the tested host sanitizer build
Required Action	Remediate, then Retest
Priority	Immediate before mission-critical integration approval
Scope Boundary	OSDLP telecommand receive and unpack paths exercised by the supplied host-based libFuzzer and AddressSanitizer runs; integrated flight software, RF delivery, hardware, and on-orbit behavior excluded

Rationale: Claim CLM-LIB-001 fails in the tested scope because two supplied runs directly demonstrate out-of-bounds reads and process termination. Missing integration context limits the conclusion's scope but does not make the demonstrated claim failure inconclusive.

2. Executive Decision Summary

The supplied libFuzzer and AddressSanitizer logs directly demonstrate two out-of-bounds reads in OSDLP telecommand-processing paths:

1. `osdlp_tc_receive` at `osdlp_tc.c:190`.
2. `osdlp_tc_unpack` at `osdlp_tc.c:110`.

Both executions terminate the fuzzing process. This is sufficient to confirm memory-safety defects in the tested host build. It is not sufficient to confirm that an external actor can reach either path in an integrated spacecraft, or that the observed process termination produces a mission-level denial of service.

Decision required: Do not approve the tested library revision for mission-critical telecommand processing until minimum-length validation is implemented, both crash cases are converted into regression tests, and

the patched library is retested in its representative integration environment.

3. Frame

Mission Context Added by the Report Author

The supplied source material does not identify a mission or integration architecture. For risk analysis, this report uses the following explicit assumption:

The OSDLP telecommand library is intended for a component whose availability and safe handling of malformed CCSDS telecommand inputs support spacecraft commandability and recoverability.

This assumption requires mission-owner confirmation.

Scope

Item	FARI Record
Primary asset	AST-LIB-TC-001 OSDLP telecommand receive/unpack library
Segment	Space segment, assumed from protocol purpose; integration not supplied
Access basis	Private, as stated by evidence producer
Environment	Host-based dynamic fuzzing with libFuzzer and AddressSanitizer
Claim	CLM-LIB-001: Truncated or malformed telecommand inputs are rejected without out-of-bounds memory access or process termination
Explicit exclusions	Integrated flight software, hardware, RF delivery, authentication, operational recovery, and on-orbit behavior

Authorization

No authorization reference, rules of engagement, test date, or evidence handling instructions were supplied. The test appears limited to a local host build, but this remains a source-material gap.

4. Acquire: Source-Material Intake Review

Method Runs

Run ID	Method	Supplied Result
RUN-LIB-001	libFuzzer against <code>libfuzzer_tc_receive</code> with AddressSanitizer	Heap-buffer-overflow read at <code>osdlp_tc.c:190</code> ; process abort
RUN-LIB-002	libFuzzer against <code>libfuzzer_tc_stream</code> with AddressSanitizer	Heap-buffer-overflow read at <code>osdlp_tc.c:110</code> ; process abort

Evidence-Backed Facts

- The project builds libFuzzer targets including `libfuzzer_tc_receive` and `libfuzzer_tc_stream`.
- RUN-LIB-001 reports an AddressSanitizer heap-buffer-overflow read of one byte in `osdlp_tc_receive` at `osdlp_tc.c:190`.
- The accessed address in RUN-LIB-001 is one byte beyond a one-byte allocated region.
- RUN-LIB-001 aborts and writes `crash-da39a3ee5e6b4b0d3255bfef95601890afd80709`.
- RUN-LIB-002 reports an AddressSanitizer heap-buffer-overflow read of one byte in `osdlp_tc_unpack` at `osdlp_tc.c:110`.
- The accessed address in RUN-LIB-002 is immediately after a five-byte allocated region.
- RUN-LIB-002 aborts and writes `crash-b32c221e6c807b39bfed6c0169f594cdae9da48a`.
- The minimized input shown for RUN-LIB-002 is `AQAFAAgAAAcAA==`.

Evidence-Producer Assertions

- The client requested validation that its developed libraries do not contain vulnerabilities.
- The engagement is described as white box and static/offline analysis.
- The evidence producer concludes that the library contains denial-of-service behavior in multiple packets.
- The evidence producer proposes a design-flaw interpretation, but the supplied material does not establish that classification.

Report-Author Inferences

- The logs demonstrate dynamic fuzzing, not only static/offline analysis.
- Process termination establishes an availability effect in the fuzz harness.
- Two separate telecommand code paths exhibit insufficient minimum-length validation or equivalent unsafe buffer access behavior.
- A mission-level denial of service is credible if untrusted input can reach the affected code in a mission-critical process, but reachability and integration effects are not demonstrated.

Assumptions

- The tested source represents the revision intended for spacecraft or spacecraft-supporting integration.
- The fuzz harness invokes the library APIs in a way permitted by their contracts.
- No upstream component is guaranteed to reject the triggering inputs.

Contradictions and Quality Issues

ID	Issue	Reporting Decision
GAP-LIB-001	Environment is labeled static/offline, but supplied evidence is dynamic fuzzing	Report uses the directly evidenced dynamic-fuzzing environment
GAP-LIB-002	“DoS in several packets” is broader than the supplied evidence	Report confirms two code-path crashes and treats mission DoS as a candidate consequence
GAP-LIB-003	Proposed EX-0005.01 mapping concerns hardware/firmware design flaws and is not the strongest description of the demonstrated C library defect	Report uses EX-0009 and treats EX-0009.01 as candidate pending integration context

Sufficiency Decision

Question	Decision	Rationale
Technical condition	Sufficient	Two direct AddressSanitizer traces identify out-of-bounds reads and process aborts
External / operational reachability	Insufficient	No integration, protocol-boundary, authentication, or RF evidence
Mission consequence	Partial	Availability effect is observed in the harness; mission effect is inferred

5. Relate: Findings and Mission Context

FND-LIB-001: Truncated Input Causes Out-of-Bounds Read in `osd_lp_tc_receive`

- **State:** Confirmed
- **Condition:** The tested receive path reads beyond a one-byte allocation.
- **Observed effect:** AddressSanitizer detects a heap-buffer-overflow at `osd_lp_tc.c:190`; the fuzz process aborts.
- **Preconditions:** A sufficiently short input reaches the affected API under conditions represented by the fuzz harness.

- **Credible mission consequence:** If reachable in an integrated mission-critical process, malformed input may terminate or destabilize telecommand processing.
- **Technical confidence:** High
- **Reachability confidence:** Low
- **Mission-consequence confidence:** Low

FND-LIB-002: Short Stream Causes Out-of-Bounds Read in `osd_lp_tc_unpack`

- **State:** Confirmed
- **Condition:** The tested unpack path reads immediately beyond a five-byte allocation.
- **Observed effect:** AddressSanitizer detects a heap-buffer-overflow at `osd_lp_tc.c:110`; the fuzz process aborts.
- **Preconditions:** A short stream equivalent to the supplied minimized input reaches the affected API under fuzz-harness conditions.
- **Credible mission consequence:** If reachable in an integrated mission-critical process, malformed input may interrupt telecommand handling.
- **Technical confidence:** High
- **Reachability confidence:** Low
- **Mission-consequence confidence:** Low

Framework Mappings

Mapping	State	Rationale
CWE-125 Out-of-bounds Read	Confirmed	Both sanitizer traces directly report reads beyond allocated memory
CWE-20 Improper Input Validation	Candidate	Minimum-length validation is a credible root cause but source and API contracts were not supplied

Qualitative Mission Context

Both findings share one provisional mission-risk scenario:

Given an actor or upstream component able to deliver a truncated telecommand-derived input, the affected library paths may read beyond valid memory and terminate a mission-critical process, potentially interrupting spacecraft commandability or recovery.

The demonstrated technical condition requires remediation before mission-critical integration approval. Operational reachability and mission consequence remain unconfirmed; they require an integration investigation and must not be represented as a numeric mission-risk score from the supplied material.

6. Inform

Required Actions

1. Add explicit minimum-length checks before every field read in `osd_lp_tc_receive` and `osd_lp_tc_unpack`.
2. Define and enforce API contracts for null, empty, truncated, and malformed inputs.
3. Preserve both minimized crash inputs as permanent regression tests.
4. Run all telecommand receive, stream, CRC, SPP, and telemetry fuzz targets with AddressSanitizer and UndefinedBehaviorSanitizer for an agreed campaign duration.
5. Validate the patched library in its integrated flight-software or representative system environment.
6. Verify upstream authentication, framing, filtering, process isolation, watchdog, and recovery controls before reducing residual risk.

Acceptance Criteria

- Both supplied crash inputs complete without sanitizer findings or abnormal termination.
- All affected APIs reject inputs shorter than their documented minimum length.
- Regression tests run in CI with sanitizers enabled.
- The mission owner confirms library placement and consequence assumptions.
- Representative integration testing demonstrates bounded recovery behavior.

Evidence Gaps and Follow-Up Requests

Gap ID	Requested Evidence	Why It Matters
GAP-LIB-004	Source revision, commit ID, compiler, sanitizer, and libFuzzer versions	Reproducibility and applicability
GAP-LIB-005	Crash artifacts and integrity hashes	Independent reproduction
GAP-LIB-006	Fuzz harness source and API contracts	Validate that calls represent supported usage
GAP-LIB-007	Complete fuzz campaign summary for every built target	Coverage and systemic-risk analysis
GAP-LIB-008	Integrated architecture and input path	Operational reachability
GAP-LIB-009	Watchdog, process isolation, recovery, and command-authentication evidence	Residual-risk evaluation
GAP-LIB-010	Mission owner and consequence definitions	Final mission-risk decision

Assurance Statement

CLM-LIB-001 **Does Not Meet** its acceptance criteria with high confidence for the tested host sanitizer build. Two out-of-bounds reads and process aborts are confirmed. The report provides low-confidence, provisional mission-risk analysis because integrated reachability, recovery controls, hardware behavior, and on-orbit effects were not assessed.

7. Coverage

Area	Coverage	Result
OSDLP TC receive path	Tested	Confirmed memory-safety defect
OSDLP TC stream/unpack path	Tested	Confirmed memory-safety defect
Other built fuzz targets	Not evidenced	Build output exists; campaign results not supplied
Integrated flight software	Not assessed	No evidence supplied
RF / link delivery	Not assessed	No evidence supplied
Hardware / on-orbit behavior	Not assessed	No evidence supplied

8. Closing FARI Result Card

Field	Result
Conclusion	Does Not Meet
Confidence	High within the tested host sanitizer scope
Required Action	Remediate, then Retest
Priority	Immediate before mission-critical integration approval
Next Decision	Approve or reject the patched library after regression and representative integration testing